

GDPR

1. Overview

GDPR (the General Data Protection Regulation) is a **European Union regulation**, effective since **May 2018**, governing the collection, processing, and protection of personal data belonging to individuals in the EU/EEA. It is widely regarded as one of the most comprehensive and influential data protection frameworks globally, and its extraterritorial reach means it applies well beyond organizations physically located in the EU.

Property	Detail
Type	Legal/regulatory — EU regulation
Jurisdiction	European Union / European Economic Area, with extraterritorial reach
Effective	May 25, 2018
Protects	Personal data of individuals ("data subjects") in the EU/EEA
Who must comply	Any organization processing EU/EEA residents' personal data, regardless of the organization's own location

2. Who Must Comply — Extraterritorial Scope

GDPR applies to any organization that:

- Is established in the EU/EEA, regardless of where the actual data processing occurs, **or**
- Is established outside the EU/EEA but offers goods or services to individuals in the EU, or monitors the behavior of individuals in the EU (e.g., through tracking/analytics).

This means a company with no physical EU presence at all can still fall fully under GDPR's jurisdiction simply by having EU customers or website visitors — a defining and frequently underestimated aspect of the regulation's reach.

3. Key Roles

Role	Definition
Data Subject	The individual whose personal data is being processed

Role	Definition
Data Controller	The entity that determines the purposes and means of processing personal data
Data Processor	The entity that processes personal data on behalf of the controller (e.g., a cloud service provider)
Data Protection Officer (DPO)	A designated individual required for certain organizations (e.g., those engaged in large-scale systematic monitoring or processing of sensitive data categories) responsible for overseeing GDPR compliance

4. Core Principles

GDPR is built around a set of foundational principles governing all personal data processing:

1. **Lawfulness, fairness, and transparency** — processing must have a valid legal basis and be clearly communicated to data subjects.
2. **Purpose limitation** — data collected for one specified purpose should not be used for an incompatible new purpose without further basis.
3. **Data minimization** — only data genuinely necessary for the stated purpose should be collected.
4. **Accuracy** — personal data must be kept accurate and up to date.
5. **Storage limitation** — data should not be retained longer than necessary for its stated purpose.
6. **Integrity and confidentiality** — appropriate security measures must protect data against unauthorized processing, loss, or damage.
7. **Accountability** — the controller must be able to demonstrate compliance with all of the above, not merely assert it.

5. Lawful Bases for Processing

Every instance of personal data processing must rest on one of six lawful bases:

- **Consent** — freely given, specific, informed, and unambiguous.
- **Contract** — processing necessary to fulfill a contract with the data subject.
- **Legal obligation** — processing required to comply with a law.

- **Vital interests** — processing necessary to protect someone's life.
- **Public task** — processing necessary for a task carried out in the public interest.
- **Legitimate interests** — processing necessary for the controller's (or a third party's) legitimate interests, balanced against the data subject's rights.

6. Data Subject Rights

GDPR grants individuals substantial rights over their own personal data:

Right	Description
Right to access	Obtain confirmation of and access to their own processed data
Right to rectification	Correct inaccurate personal data
Right to erasure ("right to be forgotten")	Request deletion of personal data under specific conditions
Right to restrict processing	Limit how their data is processed under certain circumstances
Right to data portability	Receive their data in a structured, commonly used, machine-readable format and transmit it elsewhere
Right to object	Object to processing based on legitimate interests or for direct marketing
Rights related to automated decision-making	Not be subject to solely automated decisions with significant effects, without meaningful human involvement

7. Key Organizational Obligations

- **Privacy by Design and by Default** — data protection must be embedded into systems and processes from the outset, not added as an afterthought, and default settings should be the most privacy-protective option.
- **Data Protection Impact Assessments (DPIAs)** — required for processing likely to result in high risk to individuals' rights and freedoms (e.g., large-scale processing of sensitive data, systematic monitoring).
- **Records of Processing Activities (ROPA)** — maintaining documented records of what personal data is processed, why, and how.

- **Breach notification** — notifying the relevant supervisory authority within **72 hours** of becoming aware of a personal data breach (where feasible), and notifying affected individuals directly where the breach poses a high risk to their rights and freedoms.
- **International data transfer restrictions** — transferring personal data outside the EU/EEA requires an appropriate safeguard mechanism (adequacy decisions, Standard Contractual Clauses, Binding Corporate Rules).

8. Enforcement and Penalties

Enforced by national **Data Protection Authorities (DPAs)** within each EU member state, coordinated at the EU level. GDPR's penalty structure is notably severe compared to many other frameworks:

Tier	Maximum Fine
Lower tier violations	Up to €10 million or 2% of global annual turnover, whichever is higher
Higher tier violations	Up to €20 million or 4% of global annual turnover, whichever is higher

The "whichever is higher" structure, tied to **global** (not just EU) revenue, is what makes GDPR's potential penalties disproportionately severe for large multinational organizations relative to many other compliance frameworks.

9. Common Real-World Compliance Gaps

- Inadequate legal basis documentation for specific processing activities, particularly around consent mechanisms that don't meet the "freely given, specific, informed, unambiguous" bar.
- Missing or incomplete DPIAs for high-risk processing activities.
- International data transfer mechanisms not properly documented or kept current with evolving legal requirements (a particularly dynamic area given ongoing legal challenges to various transfer mechanisms).
- Breach notification processes not tested or capable of meeting the 72-hour timeline in practice.
- Vendor/processor contracts lacking required GDPR-mandated data processing terms.

10. Summary

GDPR is a comprehensive, extraterritorially-reaching EU regulation governing personal data processing, built around core principles (lawfulness, minimization, purpose limitation, accountability, and more), six lawful processing bases, and substantial data subject rights (access, erasure, portability, and others). Its distinguishing features relative to other frameworks in this series are its broad jurisdictional reach — applying to any organization processing EU residents' data regardless of physical location — and its severe, revenue-percentage-based penalty structure, which together make it one of the highest-stakes compliance frameworks for any organization with even incidental EU customer or visitor data.